

Clase 070 — Enumeración: SMB, SNMP, SMTP y LDAP

Parte: 3 — Hacking ético y pentesting: metodología · Fuente: *The Hacker Playbook 3* (P. Kim) y *Penetration Testing* (G. Weidman) 🕒 Duración estimada: 110 min · Nivel: Intermedio

Objetivo

Extraer información detallada de los servicios más jugosos de una red corporativa: recursos compartidos y usuarios por **SMB**, dispositivos y comunidades por **SNMP**, cuentas válidas por **SMTP** y estructura del directorio por **LDAP**. La enumeración convierte "hay un puerto 445 abierto" en "hay estos usuarios y estos shares".

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Enumerar** shares, usuarios y políticas por SMB con herramientas específicas.
- 2. **Extraer** información de dispositivos vía SNMP con comunidades por defecto.
- 3. **Validar** usuarios de correo con comandos SMTP (VRFY/RCPT).
- 4. **Consultar** un directorio LDAP anónimo para mapear la organización.
- 5. **Correlacionar** los datos enumerados con vectores de ataque posteriores.

Temas

#	Tema	Por qué importa
1	SMB: shares y sesiones nulas	Fuente de archivos, usuarios y a veces credenciales
2	enum4linux / smbclient / crackmapexec	Automatizan la enumeración SMB
3	SNMP y comunidades por defecto	public / private filtran toda la config
4	SMTP VRFY/RCPT	Descubre usuarios válidos para spraying
5	LDAP anónimo	Estructura de AD sin autenticarse
6	Correlación con ataques	Cada dato alimenta la siguiente fase
7	Documentación de la enumeración	El informe necesita evidencia

Definiciones y características

- **SMB (Server Message Block):** protocolo de compartición de archivos de Windows. Característica clave: las sesiones nulas pueden listar shares y usuarios sin credenciales.
- **Sesión nula:** conexión SMB anónima. Característica clave: en sistemas antiguos revela usuarios, grupos y políticas.

- **SNMP (Simple Network Management Protocol):** gestión de dispositivos vía UDP/161. Característica clave: las comunidades `public` / `private` suelen quedar por defecto y exponen la MIB completa.
- **SMTP VRFY/RCPT:** comandos que verifican existencia de buzones. Característica clave: permiten enumerar usuarios válidos si el servidor no lo bloquea.
- **LDAP anónimo:** consulta al directorio sin autenticación. Característica clave: puede revelar OUs, usuarios y atributos de Active Directory.
- **CrackMapExec:** navaja suiza para redes Windows/AD. Característica clave: enumera y valida credenciales SMB/LDAP a escala.

Herramientas y preparación

```
sudo apt install -y enum4linux smbclient snmp snmp-mibs-downloader ldap-utils crackmapexec
```

Objetivo: **Metasploitable** o un Windows/AD de laboratorio propio en red aislada.

 **Nota ética:** la enumeración interroga servicios reales y puede quedar registrada. Prácticala solo en tu laboratorio o dentro del alcance autorizado. Nunca uses credenciales o comunidades encontradas para acceder a sistemas fuera del engagement.

Laboratorio guiado

Sustituye `TARGET` por la IP de tu objetivo de laboratorio.

1. Enumeración SMB integral:

```
bash enum4linux -a TARGET
```

2. Listar shares con smbclient (sesión nula):

```
bash smbclient -L //TARGET -N
```

3. Enumerar con CrackMapExec (shares y usuarios):

```
bash crackmapexec smb TARGET --shares crackmapexec smb TARGET --users
```

4. SNMP con comunidad por defecto:

```
bash snmpwalk -v2c -c public TARGET snmpwalk -v2c -c public TARGET 1.3.6.1.2.1.25.4.2.1.2 # procesos
```

5. Enumeración de usuarios por SMTP:

```
bash nmap -p25 --script smtp-enum-users TARGET
```

6. Consulta LDAP anónima:

```
bash ldapsearch -x -H ldap://TARGET -b "dc=ejemplo,dc=local"
```

7. Consolida usuarios, shares y hosts descubiertos en tu tabla de hallazgos.

Ejercicios

1. Lista todos los shares de tu objetivo e identifica cuáles permiten lectura anónima.
2. Extrae de SNMP la lista de procesos en ejecución del objetivo.
3. Enumera tres usuarios válidos por SMTP y explica qué comando los reveló.
4. Consulta por LDAP la unidad organizativa (OU) de usuarios.
5. Correlaciona un usuario SMB con un buzón SMTP: ¿coinciden los nombres?
6. Documenta qué harías con un share de lectura que contenga un script con credenciales.

Reto verificable

Genera un **dossier de enumeración** del objetivo: lista de shares con permisos, al menos cinco usuarios, datos SNMP relevantes (SO, procesos o interfaces) y estructura LDAP si aplica.

Criterio de aceptación: el dossier contiene ≥ 5 usuarios enumerados con la técnica que los reveló, al menos un share accesible identificado y un dato SNMP concreto (versión de SO o proceso), todo con evidencia (comando + salida).

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
<code>enum4linux</code> sin usuarios	Sesiones nulas deshabilitadas; prueba con credenciales de bajo privilegio
<code>snmpwalk</code> "Timeout"	Comunidad incorrecta o puerto filtrado; prueba <code>private</code> o <code>-v1</code>
SMTP no responde a VRFY	El servidor lo deshabilitó; usa <code>RCPT TO</code> como alternativa
<code>ldapsearch</code> "Operations error"	Falta base DN; especifica <code>-b</code> con el dominio correcto
MIBs numéricas ilegibles	Instala <code>snmp-mibs-downloader</code> y descomenta <code>mibs</code> en <code>snmp.conf</code>

Preguntas frecuentes

? ¿Por qué SMB es tan valioso en un pentest? Porque concentra archivos, usuarios y, a menudo, credenciales en scripts o configuraciones. Además, es la puerta a ataques de AD como Pass-the-Hash o relay.

? ¿SNMP sigue siendo relevante hoy? Sí, sobre todo en impresoras, routers y switches donde `public` nunca se cambió. SNMPv3 con autenticación es lo recomendable, pero muchos equipos siguen en v1/v2c.

? ¿La enumeración SMTP funciona siempre? No. Muchos servidores modernos deshabilitan VRFY y devuelven la misma respuesta para usuarios válidos e inválidos, frustrando la enumeración.

? ¿Qué hago si LDAP permite bind anónimo? Documenta la exposición: es un hallazgo. Con bind anónimo puedes mapear casi todo el directorio, lo que facilita el password spraying posterior.

Referencias

- Kim, P. *The Hacker Playbook 3* (2018).
- CrackMapExec — <https://www.crackmapexec.wiki/>
- enum4linux — <https://labs.portcullis.co.uk/tools/enum4linux/>
- MITRE ATT&CK — T1087 Account Discovery — <https://attack.mitre.org/techniques/T1087/>

Siguiente clase

Clase 071 - Analisis de vulnerabilidades con Nessus y OpenVAS